

VERTRAULICH · INTERNES DOKUMENT

Lizenz- & Rechts-Audit

Project X

DATUM	GEPRÜFT VON	REPO	STATUS
10.06.2026	Claude Code (Sonnet 4.6)	nepipo/project-x	Closed Beta

ZIELGRUPPE

Gymnasiasten 15-18 Jahre · DE

3

KRITISCH

3

HOCH

3

MITTEL

8

OK / KEIN RISIKO

01 Kritische Risiken — vor Beta beheben

Impressum unvollständig (§5 TMG)

● KRITISCH

Die Datei `/app/impressum/page.tsx` enthält nur Platzhalter: `[DEIN VOLLSTÄNDIGER NAME]`, `[STRASSE UND HAUSNUMMER]`, `[PLZ]`. Nach §5 TMG sind vollständiger Name, ladungsfähige Adresse und Telefonnummer Pflicht für jede kommerzielle Website.

Wer kann klagen: Abmahn-Anwälte ab Tag 1 nach öffentlichem Launch. In Deutschland aktiv betriebenes Geschäftsmodell — sehr hohes Risiko.

FIX → Deinen echten Namen, Privatadresse und eine Telefonnummer eintragen. Alternativ: Postfach oder Geschäftsadresse mieten (~5-15€/Monat). Kein Code-Aufwand.

Datenschutzerklärung ist faktisch falsch (DSGVO)

● KRITISCH

Die Datenschutzerklärung behauptet, Anthropic erhalte nur „anonymisierte“ Daten. Tatsächlich wird in `/app/api/coach/route.ts` der Vorname des Users direkt im System-Prompt übermittelt:

```
"Du bist ein älterer Freund von ${name}"
```

Auch in `/lib/actions/briefing.ts` enthält der Kontext personenbezogene Daten. Eine falsche Datenschutzerklärung ist selbst ein DSGVO-Verstoß und kann mit Bußgeldern belegt werden.

FIX (OPTION A, EINFACHER) → Den `${name}` -Teil aus dem Anthropic-System-Prompt entfernen. Aus "Du bist ein Freund von Max" wird "Du bist ein persönlicher Lern-Coach". Eine Zeile Code.

FIX (OPTION B) → Datenschutzerklärung korrekt anpassen: "Vorname wird an Anthropic (USA) übermittelt."

Keine AGB vorhanden

 KRITISCH

Es gibt keinerlei Nutzungsbedingungen. Sobald Zahlungen eingeführt werden (geplant: 3–5€/Monat), hat der Betreiber ohne AGB keinerlei Haftungsschutz. Fehlt auch: Mindestalter-Regelung, KI-Haftungsausschluss, Kündigungsbedingungen, Regelung zu Account-Sperrung.

Besonders riskant: Die App macht KI-basierte Aussagen über Schulnoten. Ohne AGB-Haftungsausschluss könnte ein Nutzer bei falscher KI-Prognose Schadensersatz fordern.

FIX → Mindest-AGB erstellen mit: Haftungsausschluss KI-Inhalte, Mindestalter 15 Jahre, Kündigung, Datenlöschung. Empfehlung: eRecht24 AGB-Generator (~50–150€) statt selbst schreiben — spart rechtliche Risiken.

02 Hohe Risiken — vor monetisiertem Launch

DSGVO Art. 8 — Minderjährige unter 16 ohne Eltern-Consent

 HOCH

Die Datenschutzerklärung (`/app/datenschutz/page.tsx` , Zeile 230) besagt korrekt: "Für Nutzer unter 16 Jahren ist die Zustimmung eines Erziehungsberechtigten erforderlich."

Beim Signup (`/components/auth/signup-form.tsx`) wird jedoch weder das Alter abgefragt, noch gibt es eine Checkbox oder Parental-Consent-Flow. Ein 14-Jähriger kann sich ungehindert registrieren — das verstößt gegen Art. 8 DSGVO.

FIX (PRAGMATISCH FÜR BETA) → Checkbox beim Signup: "Ich bin 16 Jahre oder älter, oder habe die Zustimmung meiner Erziehungsberechtigten." Für echten Launch: Geburtsjahrfeld + wenn <16, Eltern-Bestätigungs-E-Mail.

Kein Account-Lösch-Flow (DSGVO Art. 17)

HOCH

DSGVO Art. 17 garantiert jedem Nutzer das Recht auf Löschung. Ein Daten-Export-Button (`/api/export/route.ts`) ist vorhanden — aber kein "Account löschen"-Button in der UI. Nutzer können ihre Daten derzeit nicht selbst löschen.

Besonders heikel bei einem Minderjährigen-Service: Eltern können Löschung verlangen. Ohne UI muss manuell in Supabase gelöscht werden.

FIX → Button in `/app/(app)/einstellungen/` : "Account löschen" → Bestätigungs-Dialog → `supabase.auth.admin.deleteUser()` . Cascade-Delete ist im DB-Schema bereits konfiguriert (alle User-Daten werden automatisch mitgelöscht). Aufwand: ~1h.

Impressum widerspricht Datenschutzerklärung (kommerziell vs. Beta)

HOCH

Das Impressum sagt: *"kein kommerzielles Angebot."*

Die Datenschutzerklärung spricht von einem *"3–5€/Monat Abo-Modell"*.

Das ist ein interner Widerspruch in Rechtsdokumenten. Sobald Zahlungen eingeführt werden, ist der Impressum-Hinweis schlicht falsch — und das kann bei Verbraucherschutz-Beschwerden nachteilig sein.

FIX → Impressum-Hinweis "kein kommerzielles Angebot" für Beta korrekt lassen. Vor Stripe-Launch: Impressum auf "kommerzielles Angebot" umstellen und Datenschutz entsprechend aktualisieren.

03 Mittlere Risiken — v1.0 Maßnahmen

Stundenplan-Fotos werden an Anthropic (USA) gesendet

MITTEL

Das Stundenplan-Import-Feature (`/lib/actions/stundenplan-import.ts`) sendet User-Fotos base64-kodiert an Claude Vision. Die Fotos können Lehreramen, Raumbezeichnungen oder

andere personenbezogene Daten enthalten. Die Datenschutzerklärung erwähnt dieses Feature nicht explizit.

FIX → Absatz in Datenschutzerklärung ergänzen: "Beim Stundenplan-Import per Foto wird das Bild zur OCR-Verarbeitung an Anthropic (USA) übertragen und dort nicht dauerhaft gespeichert."

Keine KI-Transparenzhinweise in der UI (EU AI Act)

● MITTEL

Beim KI-Coach-Chat und beim Briefing ist nur ein Label "KI" sichtbar. Es fehlt ein Hinweis, dass Daten zu einem US-Dienst (Anthropic) übertragen werden. Der EU AI Act (ab 2026 vollständig in Kraft) wird Transparenzpflichten für KI-Interaktionen verschärfen.

FIX → Kleiner Hinweis unter dem Coach-Chat: "Powered by Anthropic Claude · Deine Daten werden zur Verarbeitung an Anthropic (USA) übermittelt. · Datenschutz" — verlinkt zur Datenschutzerklärung.

Supabase / Vercel DPA nur behauptet, nicht verifiziert

● MITTEL

Die Datenschutzerklärung sagt, ein DPA (Data Processing Agreement) mit Supabase "liegt vor." Für eine neue App wurde dies jedoch nicht aktiv abgeschlossen — Supabase stellt ein Standard-DPA bereit, das über die Dashboard-Einstellungen aktiviert werden muss.

FIX → Supabase Dashboard → Settings → Legal → DPA aktivieren/bestätigen. Vercel hat ein Auto-DPA in den ToS für Pro/Enterprise — Free-Tier-Nutzer sollten prüfen ob das DPA greift.

04 Lizenz-Status aller Ressourcen

Open-Source-Abhängigkeiten

✓ ALLE OK

Alle npm-Pakete nutzen Open-Source-Lizenzen die kommerzielle Nutzung erlauben.

PAKET	LIZENZ	KOMMERZIELLE NUTZUNG
Next.js 16	MIT	● Erlaubt
React 19	MIT	● Erlaubt
Tailwind CSS v4	MIT	● Erlaubt

shadcn/ui + @base-ui/react	MIT	● Erlaubt
lucide-react	ISC	● Erlaubt
sonner, clsx, tailwind-merge	MIT	● Erlaubt
@anthropic-ai/sdk	Apache 2.0	● Erlaubt
@supabase/* (SDK)	Apache 2.0	● Erlaubt
web-push	MIT	● Erlaubt
tw-animate-css	MIT	● Erlaubt

Fonts (Google Fonts via next/font)

✓ OK

Bricolage Grotesque, Onest und JetBrains Mono werden via `next/font/google` geladen — das bedeutet: selbst-gehostet, keine direkte Google-Verbindung zur Laufzeit, DSGVO-konform. Alle drei Fonts stehen unter der **SIL Open Font License (OFL)**, die kommerzielle Nutzung ausdrücklich erlaubt.

Bereits behoben: Google Fonts CDN-Links in `docs/*.html` wurden durch System-Font-Stack ersetzt (10.06.2026).

Boilerplate-SVGs aus /public

✓ BEREINIGT

Bereits bereinigt (10.06.2026): Die fünf create-next-app-Boilerplate-Assets (`file.svg` , `globe.svg` , `next.svg` , `vercel.svg` , `window.svg`) wurden aus `/public/` gelöscht. Das Verzeichnis enthält jetzt nur noch `sw.js` (eigener Service Worker).

Cookies & Tracking

✓ DSGVO-KONFORM

Es werden ausschließlich **funktionale First-Party-Cookies** gesetzt: Supabase Session-Cookie (Auth), `project-x-theme` (Dark/Light), `project-x-accent` (Akzentfarbe). Kein Tracking, keine Werbe-Pixel, keine Analytics-Drittanbieter. Ein Cookie-Consent-Banner ist für diese Konfiguration nach DSGVO/ePrivacy nicht erforderlich.

Web Push Notifications

✓ OPT-IN KORREKT

Push-Notifications sind standardmäßig deaktiviert. Aktivierung nur durch expliziten Klick + Browser-Permission-Dialog. Deaktivierung jederzeit möglich. DSGVO Art. 7 (informierte Einwilligung) und ePrivacy-Richtlinie werden eingehalten.

Datenbank-Sicherheit (RLS)

✓ OK

Row Level Security ist auf allen 8 Tabellen aktiviert. Kaskadierendes Löschen ist konfiguriert (User-Löschung entfernt automatisch alle verknüpften Daten). Supabase-Projekt läuft in Frankfurt/EU (AWS eu-central-1) — DSGVO-konformer Serverstandort.

05 Priorisierte Handlungsliste

Vor Beta-Launch (Blocker)

SOFORT

- 01 Impressum ausfüllen — Name, Adresse, Telefon (§5 TMG). Kein Code-Aufwand.
- 02 Name aus Anthropic-System-Prompt entfernen (`coach/route.ts` + `briefing.ts`). Eine Zeile Code.
- 03 Alters-Checkbox beim Signup: "Ich bin 16+ oder habe Eltern-Zustimmung." ~30 Min.
- 04 "Account löschen"-Button in Einstellungen. Cascade-Delete bereits konfiguriert. ~1h.
- 05 AGB erstellen — eRecht24 Generator empfohlen (~50–150€), nicht selbst schreiben.

Vor Monetisierung / Stripe-Launch

V1.0

- 06 Datenschutzerklärung: Stundenplan-Foto-Import-Absatz ergänzen.
- 07 KI-Transparenz-Hinweis im Coach-Chat-UI ("Powered by Anthropic · Datenschutz").
- 08 Supabase DPA im Dashboard aktivieren/bestätigen.
- 09 Impressum + Datenschutz auf "kommerziell" umstellen wenn Stripe live geht.
- 10 Stripe Privacy Policy in Datenschutzerklärung ergänzen.

Project X · Nepomuk Polonius · Hamburg

Vertrauliches internes Dokument — nicht zur Weitergabe bestimmt

Audit-Datum: 10.06.2026

Erstellt mit Claude Code